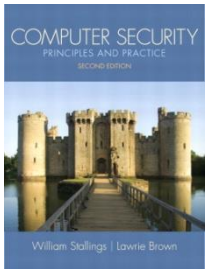
אבטחת סייבר

(אבטחת מידע/מחשבים/מערכות ממוחשבות/...)



המצגת הינה לשימוש פנימי בלבד

אין לצלם או לעשות שימוש שלא במסגרת הקורס

אבטחת מידע
ברשת האינטרנט

מודל רשת ה- Internet

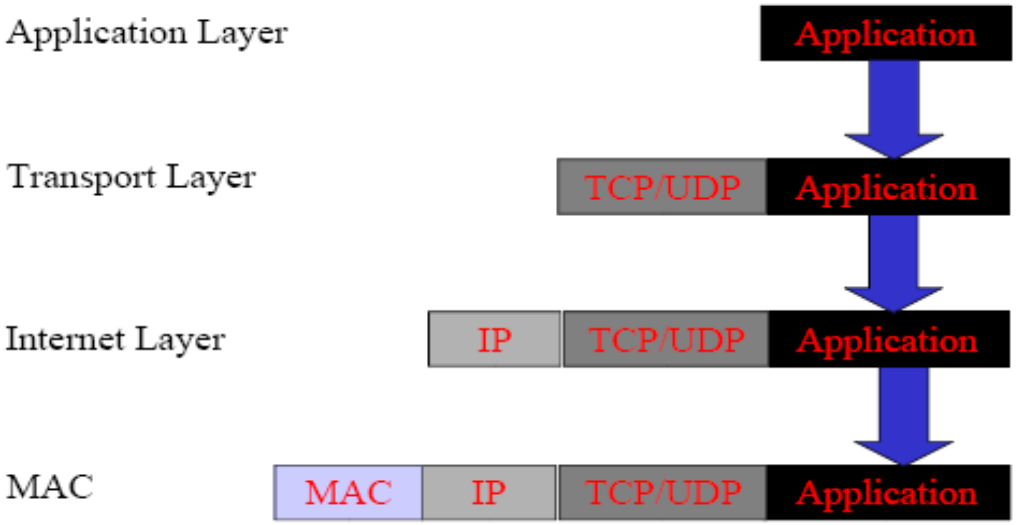
Application
TCP (תובלה)
IP (רשת)
MAC (פיזית)

בשל המורכבות העבודה מתחלקת בין שכבות.

כל שכבה מתקשרת פיזית עם השכבות הסמוכות לה, ולוגית עם השכבה המקבילה לה.

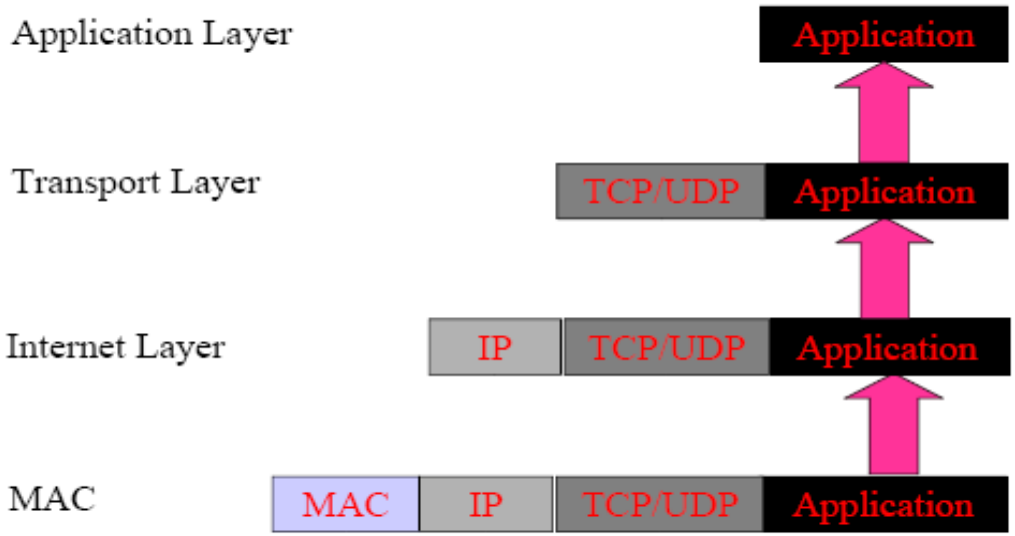
מודל רשת ה-Internet

עיבוד חבילה בשליחה



מודל רשת ה-Internet

עיבוד חבילה בקבלה



מודל רשת ה-Internet

מבנה החבילה ותפקיד כל שכבה

- MAC header – משתנה לפי המדיה הפיזית. מכיל את כתובת ה-MAC ואינפורמציה נוספת.
- IP header – מכיל בין היתר: כתובות IP של השולח, והמקבל, TTL, הפרוטוקול הבא (TCP/UDP או אחר), וגרסת פרוטוקול IP.
- UDP/TCP header מכיל: מספרי הפורטים של השולח והמקבל. TCP מכיל בנוסף חיוויים (syn/ack) ומספרים סידוריים.

מודל רשת ה-Internet

מושגים במודל שצריך להכיר (רשימה חלקית):

Connectionless/Connection oriented

Reliable/Unreliable

3-way handshake (SYN, SYN-ACK, ACK)

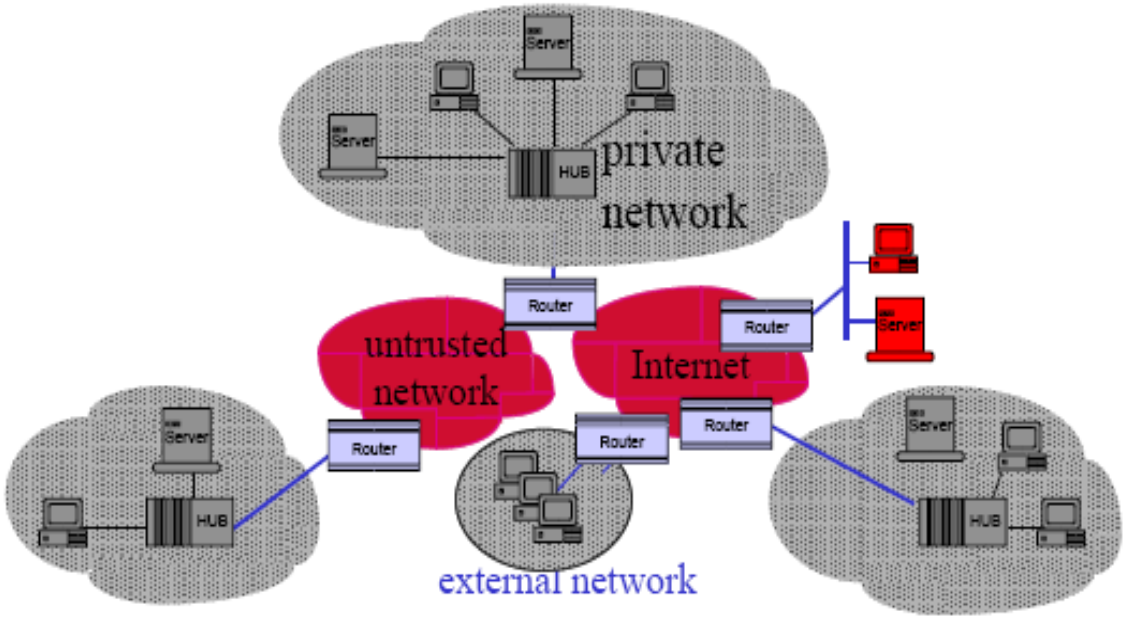
Gateways

Ports

Sockets

מודל רשת ה-Internet

עולם הרשת



איומים על רשתות תקשורת

רשתות מחשבים נועדו להקל על המשתמשים – ניתן למצוא מידע בקלות, קל להעביר אותו ממקום למקום וכו'.

הבעיה הנלווית היא שקל למצוא את המידע, שקל להעביר אותו וכו' – גם לתוקפים.

קיים trade-off בין נוחות השימוש ברשת לבין בטיחות המידע:

- התחברות לרשת יוצרת נקודות תורפה, דרכן ניתן לפרוץ למערכת.
- ביזור נתונים ומשאבים דורש לאבטח נקודות תורפה רבות.
- יש שירותים רבים (ורובם לא מוגנים).
- כל שכבה ברשת חשופה להתקפות באופן בלתי תלוי בשכבות האחרות

התקפות ב-Internet

- Sniffing
- Syn Attack
- DNS Poisoning
- IP Spoofing: שינוי כתובת ה-IP של ה-host
  - לעיתים הזיהוי מתבסס רק על כתובת ה-IP
  - כתובת התוקף לא מוסגרת
  - מאפשר "לבזר" התקפות

(בדר"כ התשובה לא תישלח למתחזה)

התקפות ב-Internet

- Port scan
- זיהוי אפליקציות רצות על השרת
- Social engineering- מאוד שימושי בריגול תעשייתי
- סיור שטח ואגירת מידע
- ועוד...

הגנות ברשת

- ניתן לסווג את בעיות האבטחה לשני תתי-סוגים:
  - בעיות הנובעות מחשיפת המחשב לעולם
  - בעיות הנובעות מארכיטקטורת הרשת (מודל השכבות)

- לפיכך, ניתן לדבר על שני סוגי הגנה:
- Firewalls/IDS/IPS- לצמצום החשיפה לעולם
- פרוטוקולי אבטחה- להגנה על כל שכבה בנפרד

הגנות ברשת

- Firewalls מספקים הגנה על נתונים/משאבים "נייחים" בתוך הרשת המוגנת.
- המטרה של פרוטוקולי אבטחה: להגן על נתונים בזמן מעבר ברשת (לספק סודיות, שלמות, אימות השולח ועוד).
- מטרה נוספת: מניעת התקפות נוספות- למשל, חטיפת הקשר ו-syn attack.

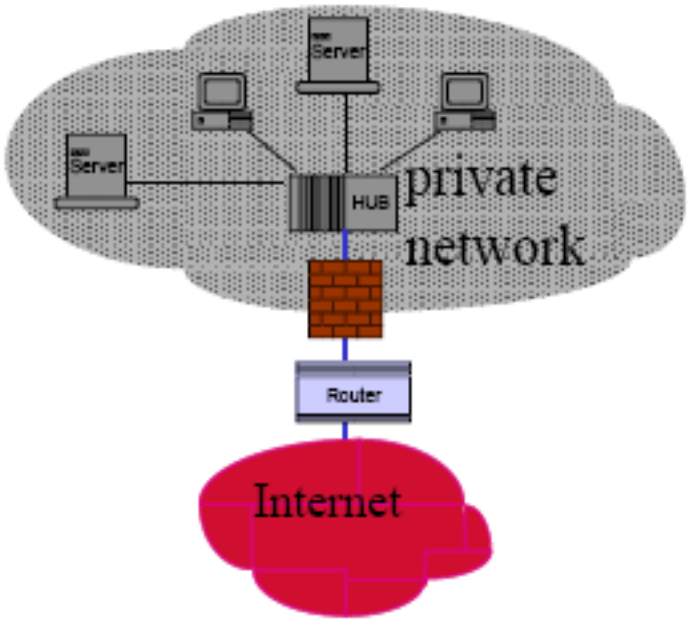
Firewall

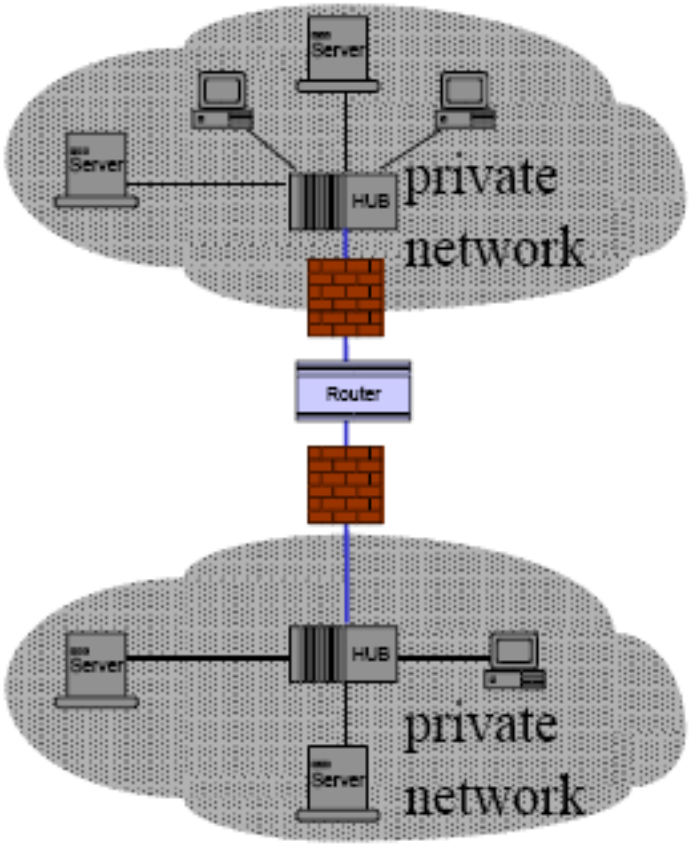
- Firewall היא מערכת שמפרידה בין שני אזורים ברשת וכופה מדיניות אבטחה על התקשורת ביניהם.
- האזורים יכולים להיות:
  - רשת פרטית/ציבורית
  - תתי רשתות של ארגון בעלות סיווגים שונים (הרשת של מחלקת כספים וכל המחלקות האחרות)
- Firewall מבצע סינון של התעבורה העוברת בין אזורים שונים.
- Firewall יכול להיות מורכב ממחשב או נתב בודד, או מאוסף מחשבים, נתבים וכו'.

Firewall

- Choke point – ניתוב כל התעבורה דרך נתיב צר. כל זרימת המידע אל העולם החיצוני וממנו עוברת דרך ה-Firewall
- Fail safe – נפילה איננה גוררת פריצה, אך במקרה זה התעבורה מנותקת!
- מבנה פשוט
- שקיפות למשתמש הקצה

Firewall


Server
Server
HUB
private
network
Router
Internet


Server
Server
HUB
private
network
Router
Server
HUB
Server
private
network

Firewall

- ניתן לחלק לשלשה סוגים:
  - Packet Filter (stateless)- מסנן את החבילות לפי כללים סטאטיים
  - Stateful PF- משתמש בכללים דינאמיים העוקבים אחרי מצב ההתקשרות
  - Proxy servers- התערבות אקטיבית בין המשתמש לשרת המרוחק

דוגמה -Stateless PF

- נניח שברשת שלנו-N1, אנו מעוניינים לאפשר לכל המחשבים לבצע telnet לכל מחשב מחוץ לרשת פרט למחשב אחד- C1.
- כמו כן נרצה לאפשר חיבור HTTP בין ה- Web Server, S1, לכל המחשבים באינטרנט.
- בנוסף, נרצה למנוע התחזות של מחשבים מחוץ לרשת למחשב פנימי.
- כל תקשורת אחרת אסורה.

דוגמה -Stateless PF

Rule	In/ Out	Src adr.	Dst adr.	Next prot.	Src port	Dst port	TCP flag	Action
spoof	in	N1	any	any	any	any	any	deny
no_telnet1	out	C1	any	TCP	>1023	23	any	deny
no_telnet2	in	any	C1	TCP	23	>1023	any	deny
telnet1	out	N1	any	TCP	>1023	23	any	permit
telnet2	in	any	N1	TCP	23	>1023	ack	permit
HTTP1	in	any	S1	TCP	>1023	80	any	permit
HTTP2	out	S1	any	TCP	80	>1023	ack	permit
default	any	any	any	any	any	any	any	deny

telnet- פורט 23
http- פורט 80
פורט כללי- 1023<

Active/Passive FTP

- במצב של FTP אקטיבי הלקוח פונה לפורט 21 של השרת לאתחול הקשר, ובאותו זמן מעביר לו מספר פורט בו הוא מעוניין לקבל את ה-Data.
- בשלב השני השרת פונה מפורט 20 ויוזם קשר לפורט של המשתמש
- הטבלה תראה כך:

Rule	In/ Out	Src adr.	Dst adr.	Next prot.	Src port	Dst port	TCP flag	Action
ftp_21_1	out	N1	any	TCP	>1023	21	any	permit
ftp_21_2	in	any	N1	TCP	21	>1023	ack	permit
ftp_20_1	in	any	N1	TCP	20	>1023	any	permit
ftp_20_2	out	N1	any	TCP	>1023	20	ack	permit

נשים לב כי החוק השלישי מאפשר לתוקף ליזום קשר מפורט 20 שלו למחשב פנימי שפתח פורט 1023<.

Active/Passive FTP

- במצב של FTP פאסיבי הלקוח פונה לפורט 21 של השרת לאתחול הקשר, אך הפעם השרת מעביר לו מספר פורט בו יועבר ה-Data.
- בשלב הבא הלקוח פונה מפורט כלשהו ויוזם קשר לפורט שקיבל מהשרת.
- במקרה זה הטבלה תראה כך:

Rule	In/ Out	Src adr.	Dst adr.	Next prot.	Src port	Dst port	TCP flag	Action
ftp_21_1	out	N1	any	TCP	>1023	21	any	permit
ftp_21_2	in	any	N1	TCP	21	>1023	ack	permit
ftp_data_1	out	N1	any	TCP	>1023	>1023	any	permit
ftp_data_2	in	any	N1	TCP	>1023	>1023	ack	permit

הפעם אין אפשרות ליזום קשר אל מחשב פנימי בעזרת החוקים הללו. נשים לב כי השרת צריך לנקוט בצעדי מניעה מתאימים שהרי הפעם ניתן ליזום קשר לפורטים גבוהים בשרת.

Stateful PF

- נשים בטבלה חוק סטטי המאפשר לכל המחשבים ב-N1 לבצע telnet:
  telnet: out, N1, any, TCP, >1023, 23, syn, permit

- כעת נניח שמשתמש C מ-N1 מעוניין להתחבר לשרת ה-telnet של מחשב RC אשר נמצא באינטרנט. לצורך כך C שולח חבילה מפורט 1049 שלו לפורט 23 של RC. כיוון שבטבלה קיים חוק סטטי המאפשר קשר זה, ה-Firewall יוסיף לטבלת החוקים את השורות הדינאמיות הבאות:
  telnet1: out, C, RC, TCP, 1049, 23, ack, permit
  telnet2: in, RC, C, TCP, 23, 1049, ack, permit

- השורות הדינאמיות שנוספו לטבלה יוסרו ממנה לאחר סגירת הקשר בין C ל-RC (ב-TCP סגירת קשר נעשית בצורה מסודרת ולכן ניתן לזהותה מתוך חבילות ה-TCP) או לחלופין לאחר timeout.
- באופן דומה ניתן לאפשר קשר FTP אקטיבי, אולם יש לאפשר ל-Firewall גישה למידע ברמת האפליקציה (בכדי לדעת את מס' הפורט בו יועבר ה-data כך שיתאפשר הקשר אליו).

Proxy server

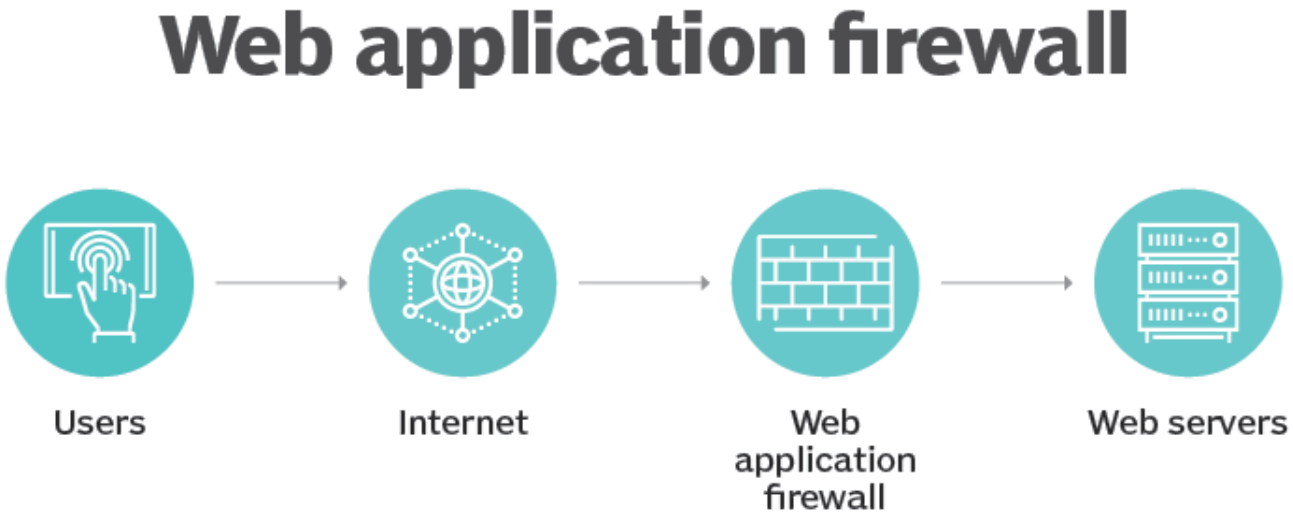
- Proxy server יכול לבצע פעולות מסובכות יותר מקודמיו- למשל לבדוק שקובץ שהתקבל משרת ftp לא מכיל וירוסים.
- כאשר החבילות עוברות אצל ה-Proxy Server, ה-Proxy Server מבצע בדיקות על המידע המועבר בין שני המחשבים ועל סמך אותן בדיקות מחליט מה לעשות עם החבילה. לשם כך על ה-Proxy Server להכיר את הפרוטוקול עליו הוא מען (telnet למשל). לכן, באופן כללי כל Proxy Server יגן על אפליקציה יחידה (telnet או http, למשל).

דוגמאות לפעולות ש-Proxy Server יכול לבצע:

- לחכות שיגיעו אליו חבילות שמכילות מספיק מידע כדי להחליט מה לעשות.
- להעביר את המידע, לזרוק או לשנות אותו.
- לגרום לכך שהמשתמש לא יראה תמונות בדפים המבוקשים על ידי הדפדפן שלו.
- לדאוג שרק משתמשים מסויימים יקבלו מידע מה-Proxy Server או לבצע אימות של המשתמש (למשל ע"י דרישת סיסמה מהמשתמש לפני מתן השירות).
- להכניס תוכנת אנטי-וירוס על קבצים שנכנסים לארגון.
- לדאוג שב-FTP קבצים יועברו רק מהאינטרנט לתוך הרשת הפנימית אולם לא יועברו מהרשת הפנימית החוצה.

WAF

- Reverse proxy



Firewalls- המצב כיום

- יעילות חסימת ההתקפות של firewalls ירדה משמעותית בשנים האחרונות
- תעבורה עוקפת firewall: לדוגמא מחשבים ניידים
- התקפות על פורטים שלרוב פתוחים ב-firewalls: לדוגמא פורט 80
- אין זה אומר שהשימוש ב-firewall מיותר, אלא שהוא אינו מספיק, בדר"כ.

Security Intrusion & Detection

Security Intrusion

a security event, or combination of multiple security events, that constitutes a security incident in which an intruder gains, or attempts to gain, access to a system (or system resource) without having authorization to do so.

Intrusion Detection

a security service that monitors and analyzes system events for the purpose of finding, and providing real-time or near real-time warning of attempts to access system resources in an unauthorized manner.

Hacker Behavior Example

1. select target using IP lookup tools
2. map network for accessible services
3. identify potentially vulnerable services
4. brute force (guess) passwords
5. install remote administration tool
6. wait for admin to log on and capture password
7. use password to access remainder of network

Criminal Enterprise Behavior

1. act quickly and precisely to make their activities harder to detect
2. exploit perimeter via vulnerable ports
3. use trojan horses (hidden software) to leave back doors for re-entry
4. use sniffers to capture passwords
5. do not stick around until noticed
6. make few or no mistakes.

Insider Behavior Example

1. create network accounts for themselves and their friends
2. access accounts and applications they wouldn't normally use for their daily jobs
3. e-mail former and prospective employers
4. conduct furtive instant-messaging chats
5. visit web sites that cater to disgruntled employees, such as f'dcompany.com
6. perform large downloads and file copying
7. access the network during off hours.

Intrusion Techniques

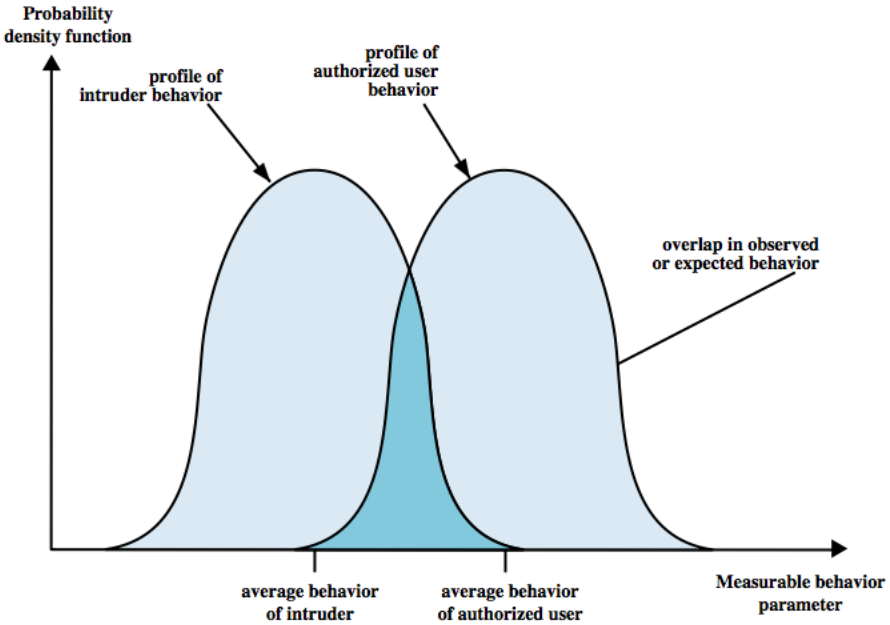
- objective to gain access or increase privileges
- initial attacks often exploit system or software vulnerabilities to execute code to get backdoor
  - e.g. buffer overflow
- or to gain protected information
  - e.g. password guessing or acquisition

Intrusion Detection Systems

- classify intrusion detection systems (IDSs) as:
  - Host-based IDS: monitor single host activity
  - Network-based IDS: monitor network traffic
- logical components:
  - sensors - collect data
  - analyzers - determine if intrusion has occurred
  - user interface - manage / direct / view IDS

IDS Principles

- assume intruder behavior differs from legitimate users
  - expect overlap as shown
  - observe deviations from past history
  - problems of:
    - false positives
    - false negatives
    - must compromise



Anomaly Detection

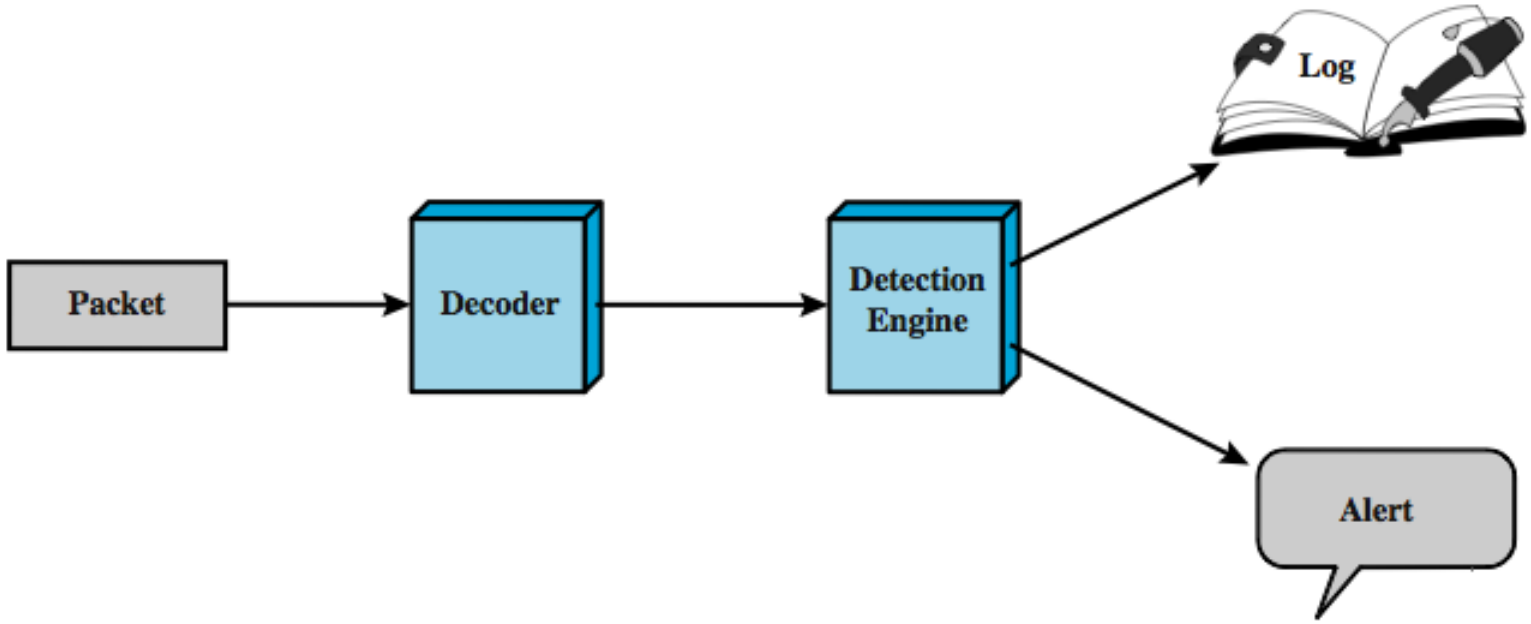
- threshold detection
  - checks excessive event occurrences over time
  - alone a crude and ineffective intruder detector
  - must determine both thresholds and time intervals
- profile based
  - characterize past behavior of users / groups
  - then detect significant deviations
  - based on analysis of audit records
    - gather metrics: counter, guage, interval timer, resource utilization
    - analyze: mean and standard deviation, multivariate, markov process, time series, operational model

Signature Detection

- observe events on system and applying a set of rules to decide if intruder
- approaches:
  - rule-based anomaly detection
    - analyze historical audit records for expected behavior, then match with current behavior
  - rule-based penetration identification
    - rules identify known penetrations / weaknesses
    - often by analyzing attack scripts from Internet
    - supplemented with rules from security experts

SNORT

- lightweight IDS
  - real-time packet capture and rule analysis
  - passive or inline



SNORT Rules

- use a simple, flexible rule definition language
- with fixed header and zero or more options
- header includes: action, protocol, source IP, source port, direction, dest IP, dest port
- many options
- example rule to detect TCP SYN-FIN attack:

```
Alert tcp $EXTERNAL_NET any -> $HOME_NET any \
(msg: "SCAN SYN FIN"; flags: SF, 12; \
reference: arachnids, 198; classtype: attempted-recon;)
```

Intrusion Prevention Systems (IPS)

- recent addition to security products which
  - inline net/host-based IDS that can block traffic
  - functional addition to firewall that adds IDS capabilities
- can block traffic like a firewall
- using IDS algorithms
- may be network or host based

פרוטוקולי אבטחה

Application
TCP (תובלה)
IPsec
IP (רשת)
MAC (פיזית)

באיזו שכבה להוסיף שירותי אבטחה?

הגדרה: נאמר שפרוטוקול אבטחה עובד ברמה x אם הוא מגן על המידע של השכבות שמעל x.
לדוגמא, הוספת הגנה ברמת הרשת:

פרוטוקול אבטחה ברמת האפליקציה

- ניתן לספק סודיות, שלמות, אי-הכחשה, הגנה נגד שידור חוזר ואימות השולח (ברמת האפליקציה).
- איננו פוגע בניתוב.
- מסופק end to end.
- איננו משבש בדיקות של firewalls.
- איננו מגן כנגד התקפות כדוגמת Syn attack.
- מחייב שינוי/עדכון האפליקציה.
- דוגמה: PGP.

פרוטוקול אבטחה ברמת התובלה

ניתן לספק סודיות, שלמות, הגנה נגד שידור חוזר ואימות השולח.

- אינו פוגע בניתוב.
- ניתן לספק end to end.
- איננו משבש בדיקות של firewalls.
- איננו מגן כנגד התקפות על שכבות התובלה כדוגמת Syn attack.
- שקוף לאפליקציה.
- דוגמה: SSL/TLS

פרוטוקול אבטחה ברמת הרשת

- ניתן לספק סודיות, שלמות, הגנה נגד שידור חוזר ואימות השולח (ברמת ה-IP).
- איננו פוגע בניתוב.
- ניתן לספק end to end או gateway to gateway.
- משבש בדיקות של firewalls.
- שקוף ל-transport ולאפליקציה.
- ניתן להגן נגד התקפות על שכבות התובלה (כגון syn attack).
- דוגמא: IPsec.

פרוטוקול אבטחה ברמה הפיזית

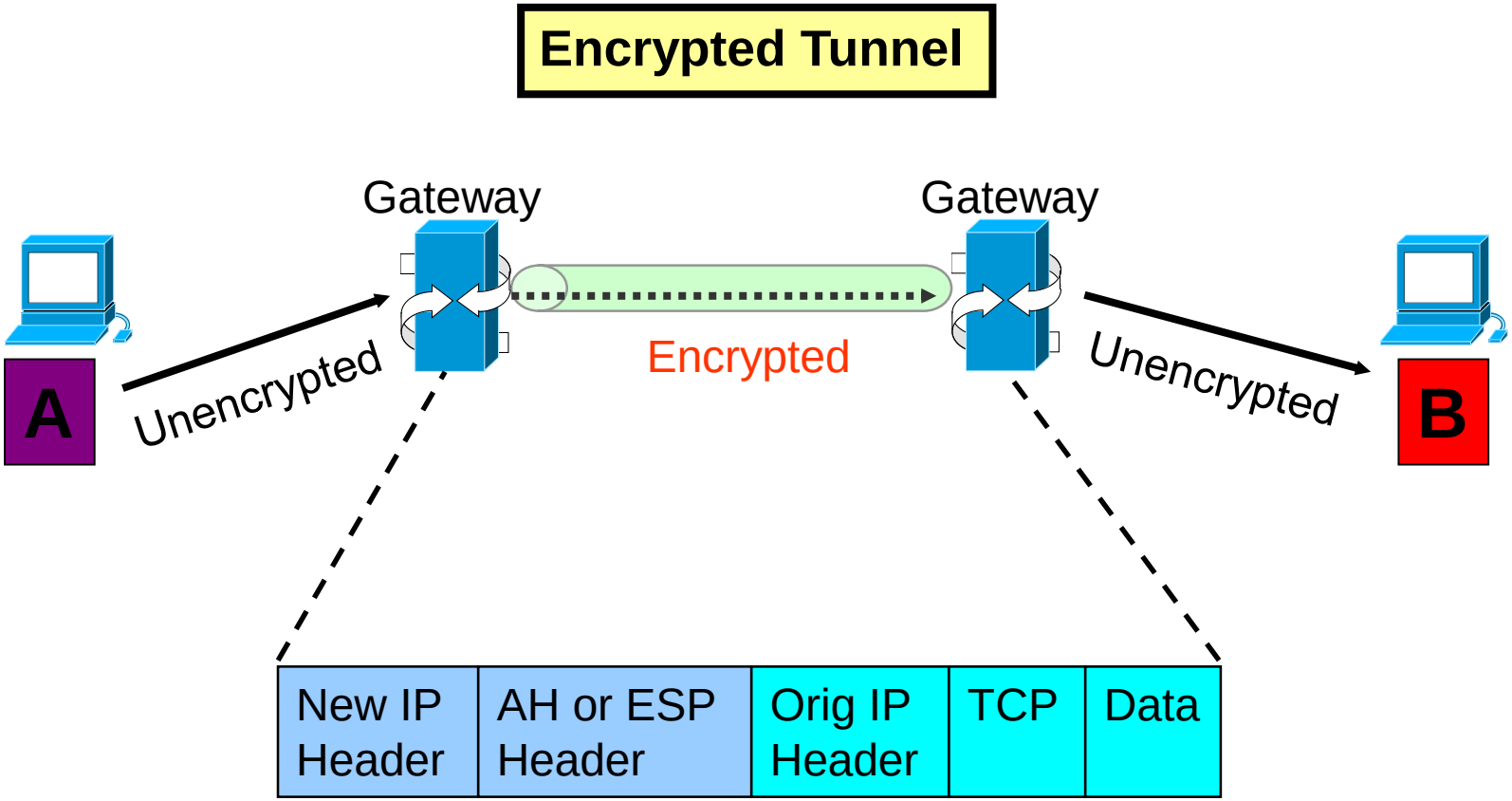
- ניתן לספק סודיות, שלמות ואימות השולח (ברמת ה-MAC).
- תלוי מדיה פיזית.
- hop by hop – כלומר בין כל שתי נקודות בניתוב צריך להחליף את שכבות ההגנה.
- מגן על החלק הגדול ביותר מה-datagram.
- שקוף ל-IP ומעלה (כי כל תחנה שמטפלת מורידה את שכבות ההגנה ברמת ה-MAC)
- דוגמא: WEP/WPA/WPA2.

IPSec- אבטחה ברמת הרשת

- IPSec מכיל את הפרוטוקולים הבאים
  - שני פרוטוקולים לאבטחת תעבורת IP:
    - ESP – מספק הצפנה ו/או אימות
    - AH – מספק אימות בלבד
  - פרוטוקול לניהול והחלפת מפתחות IKE.
- ניתן להשתמש ב-IPSec בשני אופנים:

- Transport Mode- בין מחשבי קצה
- Tunnel Mode- באופן שקוף למשתמש (למשל ליצירת VPN)

Tunnel mode


Encrypted Tunnel
Gateway
Gateway
A
Unencrypted
Encrypted
Unencrypted
B
New IP Header
AH or ESP Header
Orig IP Header
TCP
Data

IPSec

- ערוץ IPSec מוקם רק בין מכונות שיש ביניהן אמון הדדי.
- את האמון ניתן ליצור באמצעות החלפת מפתחות ארוכי-טווח.
- מפתחות אלה יכולים להיות מפתחות פומביים (יש שימוש ב-PKI שמוגדר ע"י X.509) או מפתחות סימטריים (מעין "סיסמא" משותפת).
- האמון ההדדי בין המכונות מאפשר צמצום החשיפה ל-syn attack וכנגד DoS.
- עם זאת, אם מכונה A ומכונה B בעלות אמון הדדי, ותוקף משתלט על מכונה A, הוא יוכל להשתמש בה לצורך תקיפת B.

IPSec

- כל מחשב שמותקן בו IPSec, מחזיק מבנה נתונים שנקרא Security Association Database, או בקיצור SAD.
- מבנה נתונים זה מחזיק רשומות שנקראות Security Association (ובקיצור SA).

IPSec

SAD מורכב מ-

- רשומות שנקראות SA (Security Association)
- אינדקסים של הרשומות שנקראים SPI (Security Parameter Index)
- מכיוון שהתוכן של SA משותף לשתי מכונות, לכל SA יש שני SPI, אחד במכונה A והשני במכונה B

SSL/TLS

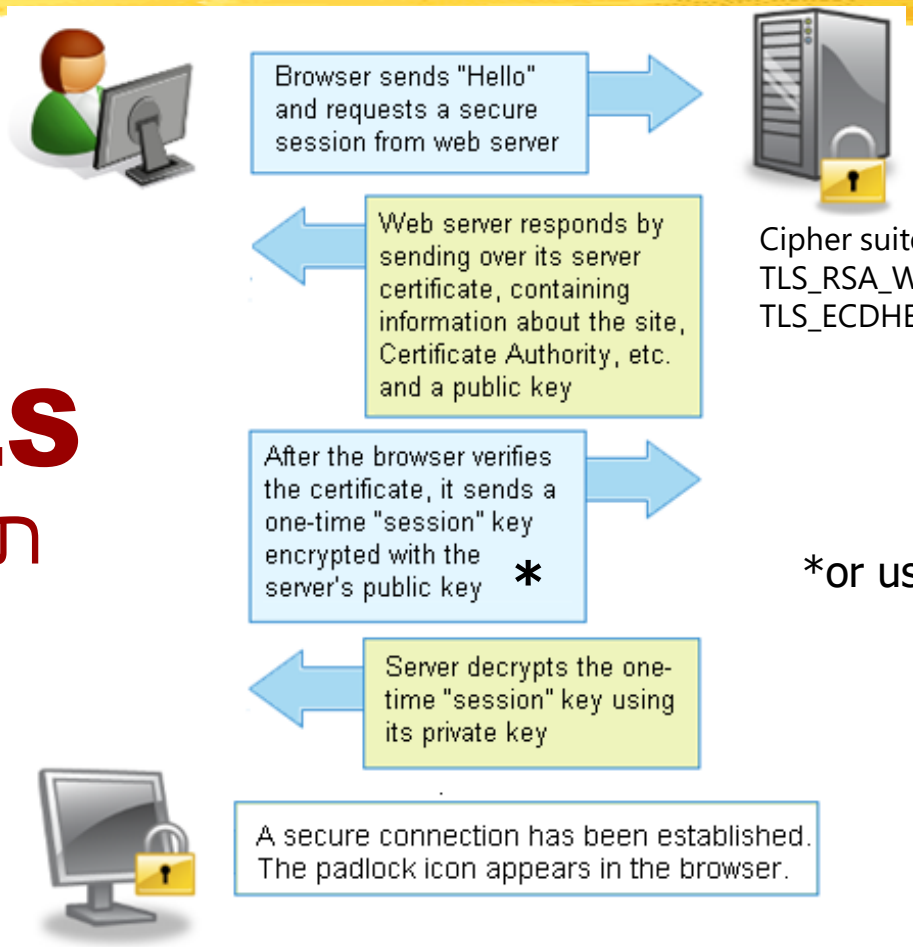
- עם תחילת השימוש במסחר האלקטרוני היה חשש לגבי בטיחות המידע הנשלח ברשת.
- על מפתחי האפליקציה נגזר להוסיף אמצעי בטיחות בתוך האפליקציה.
- בשנת 1994 פיתחה Netscape Communications את פרוטוקול ה- SSL (Secure Socket Layer).
- פרוטוקול הממומש כמעין שכבה נוספת בפרוטוקול השכבות, בין שכבות האפליקציה והתובלה.
- הפרוטוקול מספק לשכבת האפליקציה שמעליו:
  - אימות זהות (השרת ו/או הלקוח).
  - שלמות.
  - אימות ההודעות.
  - סודיות להודעות.
- פרוטוקול זה נחשב כיום כסטנדרט במסחר אלקטרוני.
- הגרסה הסטנדרטית נקראת גם TLS (Transport Layer Sec.).

SSL/TLS

Application
SSL Record
TCP
IP
MAC

- יש צורך בהבחנה האם אפליקציה מסוימת (למשל http), מוגנת ע"י SSL או שלא. לצורך כך לכל מוקצה גם port נוסף בו תשתמש כאשר עובדת עם SSL.
- לדוגמא: http מעל SSL (https) עובד בפורט 443, בעוד ש-http רגיל עובד בפורט 80.

SSL/TLS Handshake Protocol



Cipher suites example:
TLS_RSA_WITH_AES_256_CBC_SHA256
TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384

*or use DHE

rest of session is encrypted with session key

SSL/TLS
תאור סכמטי

Diffie-Hellman Key Exchange

- first published public-key algorithm
- by Diffie and Hellman in 1976 along with the exposition of public key concepts
- used in a number of commercial products
- practical method to exchange a secret key securely that can then be used for subsequent encryption of messages
- security relies on difficulty of computing discrete logarithms

Diffie-Hellman: Key Exchange Algorithm

Global Public Elements	
q	Prime number
α	$\alpha < q$ and α a primitive root of q

User A Key Generation	
Select private X_A	$X_A < q$
Calculate public Y_A	$Y_A = \alpha^{X_A} \bmod q$

User B Key Generation	
Select private X_B	$X_B < q$
Calculate public Y_B	$Y_B = \alpha^{X_B} \bmod q$

Generation of Secret Key by User A
$K = (Y_B)^{X_A} \bmod q$

Generation of Secret Key by User B
$K = (Y_A)^{X_B} \bmod q$

Figure 21.7 The Diffie-Hellman Key Exchange Algorithm

a is Primitive root of q – if a's powers generate all the integers from so that

The the numbers:

$a \bmod p, a^2 \bmod p, \ldots, a^{p-1} \bmod p$

must be distinct and between 1 to q-1

a and q are not confidential.

Public keys are known to everyone.

Diffie-Hellman: Proof

$$
\begin{aligned}
K &= (Y_B)^{X_A} \bmod q \\
&= (\alpha^{X_B} \bmod q)^{X_A} \bmod q \\
&= (\alpha^{X_B})^{X_B} \bmod q \\
&= \alpha^{X_B X_A} \bmod q \\
&= (\alpha^{X_A})^{X_B} \bmod q \\
&= (\alpha^{X_A} \bmod q)^{X_B} \bmod q \\
&= (Y_A)^{X_B} \bmod q
\end{aligned}
$$

Primitive root

- Let p be a prime
- Then b is a primitive root for p if the powers of b: 1, b, b^2, b^3, ... include all of the residue classes mod p (except 0)
- If p=7, then 3 is a primitive root for p
  1, 3, 9, 27, 81, 243 mod 7 =
  1, 3, 2, 6, 4, 5

Diffie-Hellman Example

- have
  - prime number $q = 353$
  - primitive root $\alpha = 3$
  - $X_A = 97$
  - $X_B = 233$

User A Key Generation	
Select private X_A	$X_A < q$
Calculate public Y_A	$Y_A = \alpha^{X_A} \bmod q$

User B Key Generation	
Select private X_B	$X_B < q$
Calculate public Y_B	$Y_B = \alpha^{X_B} \bmod q$

- A and B each compute their public keys
  - A computes $Y_A = 3^{97} \bmod 353 = 40$
  - B computes $Y_B = 3^{233} \bmod 353 = 248$

- then exchange and compute secret key:
  - for A: $K = (Y_B)^{XA} \bmod 353 = 248^{97} \bmod 353 = 160$
  - *for B:* $K = (Y_A)^{XB} \bmod 353 = 40^{233} \bmod 353 = 160$

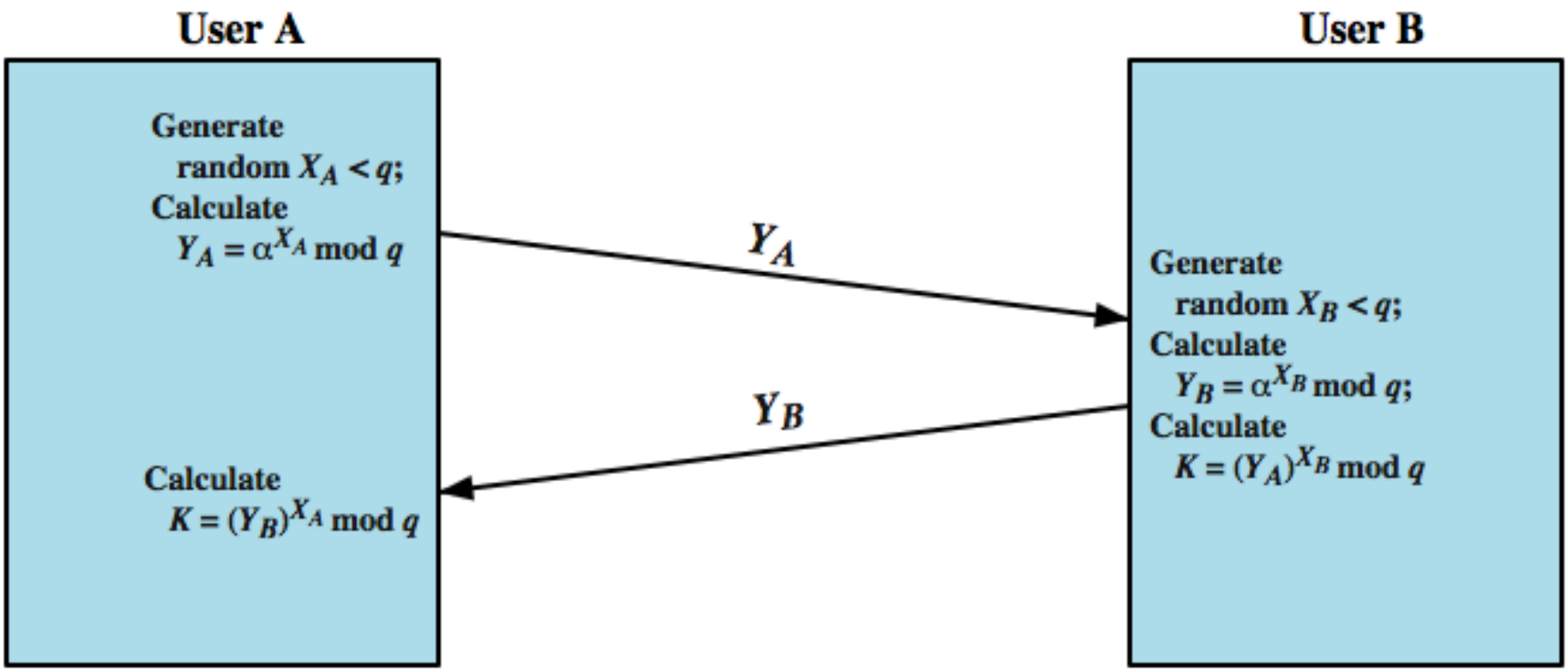
$$K = (Y_B)^{X_A} \bmod q$$

$$K = (Y_A)^{X_B} \bmod q$$

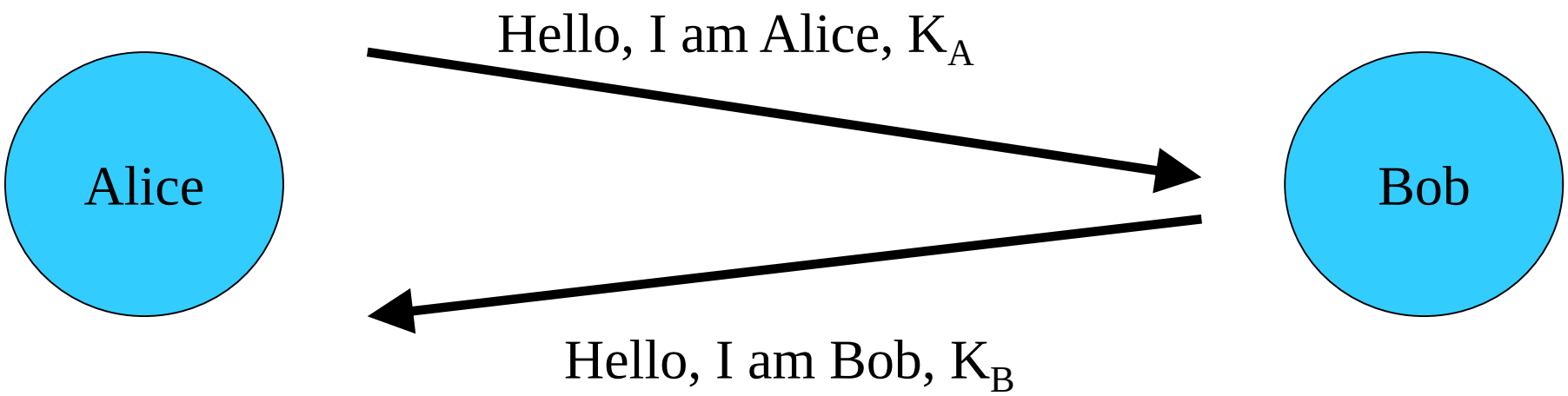
- attacker must solve:
  - $3^{Xa} \bmod 353 = 40$, with brute force which is feasible (97).
  - desired answer is 97, then compute key as B does
  - Impractical to do it for large prime numbers (α, *q)*
  - Since it is hard to calculate discrete logarithms.

$$X_B = \mathrm{dlog}_{\alpha,q}(Y_B)$$

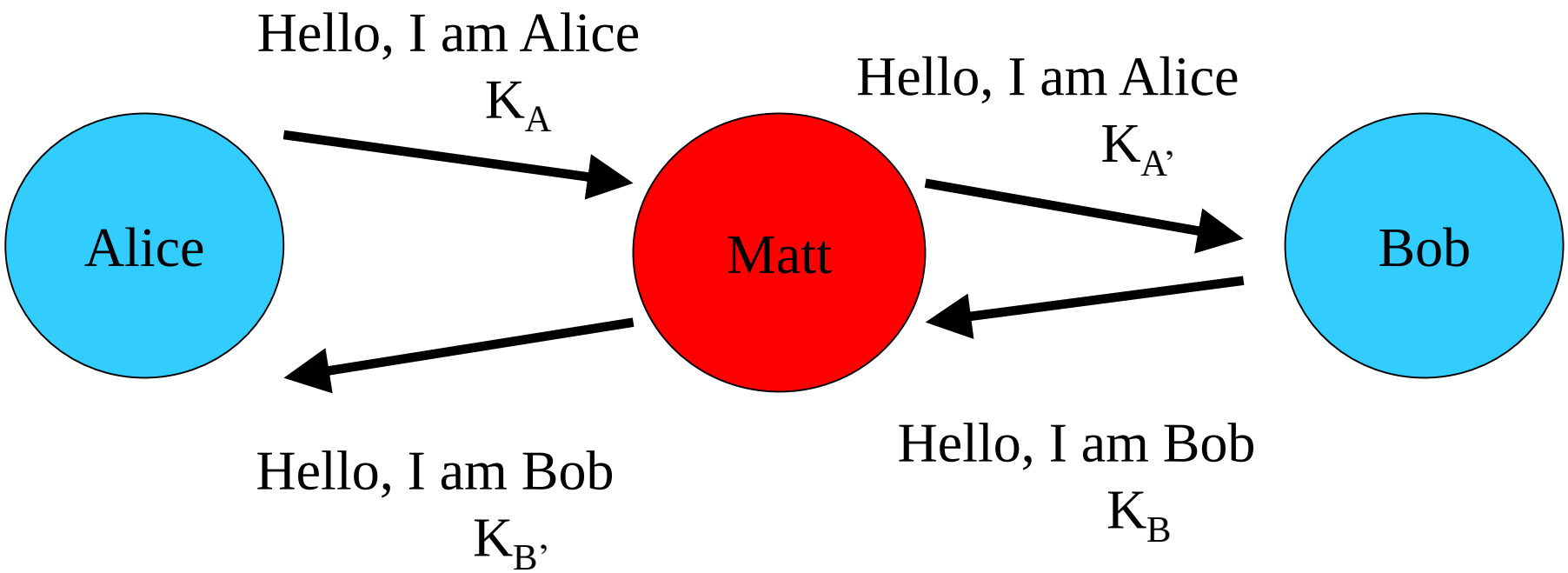
Key Exchange Protocols



Man-in-the-Middle Attack



Man-in-the-Middle Attack



Man-in-the-Middle Attack

1. Darth prepares for the attack by generating two random private keys X_{D1} and X_{D2} and then computing the corresponding public keys Y_{D1} and Y_{D2}.
2. Alice transmits Y_A to Bob.
3. Darth intercepts Y_A and transmits Y_{D1} to Bob. Darth also calculates $K2 = (Y_A)^{X_{D2}} \bmod q$.
4. Bob receives Y_{D1} and calculates $K1 = (Y_{D1})^{X_B} \bmod q$.
5. Bob transmits Y_B to Alice.
6. Darth intercepts Y_B and transmits Y_{D2} to Alice. Darth calculates $K1 = (Y_B)^{X_{D1}} \bmod q$.
7. Alice receives Y_{D2} and calculates $K2 = (Y_{D2})^{X_A} \bmod q$.

At this point, Bob and Alice think that they share a secret key, but instead Bob and Darth share secret key $K1$ and Alice and Darth share secret key $K2$. All future communication between Bob and Alice is compromised in the following way:

1. Alice sends an encrypted message M: $E(K2, M)$.
2. Darth intercepts the encrypted message and decrypts it, to recover M.
3. Darth sends Bob $E(K1, M)$ or $E(K1, M')$, where M' is any message. In the first case, Darth simply wants to eavesdrop on the communication without altering it. In the second case, Darth wants to modify the message going to Bob.

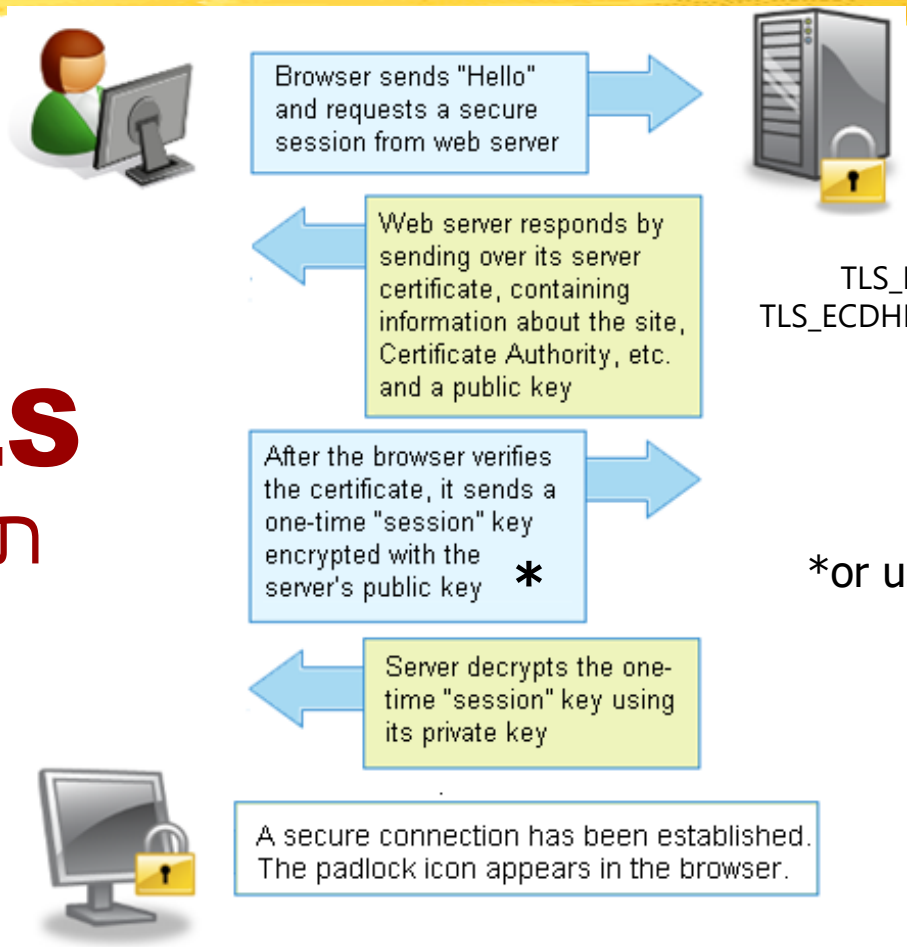
DH Protocol

- פרוטוקול Diffie-Hellman חשוף להתקפת "האיש שבאמצע"
- פתרון :
  - שימוש ב-Certificates עבור מפתחות DH.
  - חתימה על המפתח הציבורי באמצעות אלגוריתם חתימה דיגיטלית (RSA או DSA)

SSL/TLS Handshake Protocol

- is used before any application data are transmitted
- allows server & client to:
  - authenticate each other
  - to negotiate encryption & MAC algorithms
  - to negotiate cryptographic keys to be used
- comprises a series of messages in phases
  - Establish Security Capabilities
  - Server Authentication and Key Exchange
  - Client Authentication and Key Exchange
  - Finish

SSL/TLS
תאור סכמטי

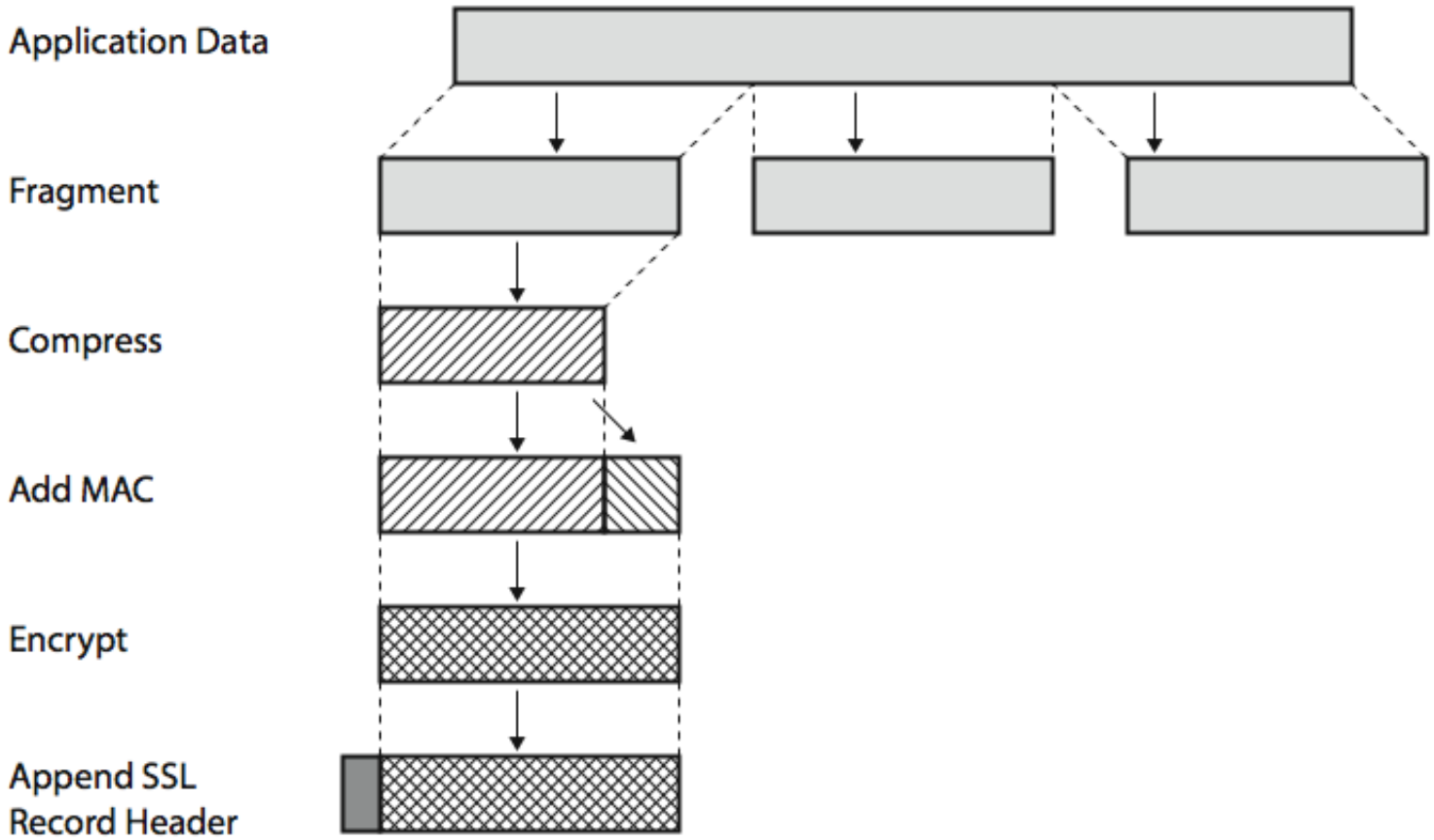


Cipher suites example:
TLS_RSA_WITH_AES_256_CBC_SHA256
TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384

*or use DHE

rest of session is encrypted with session key

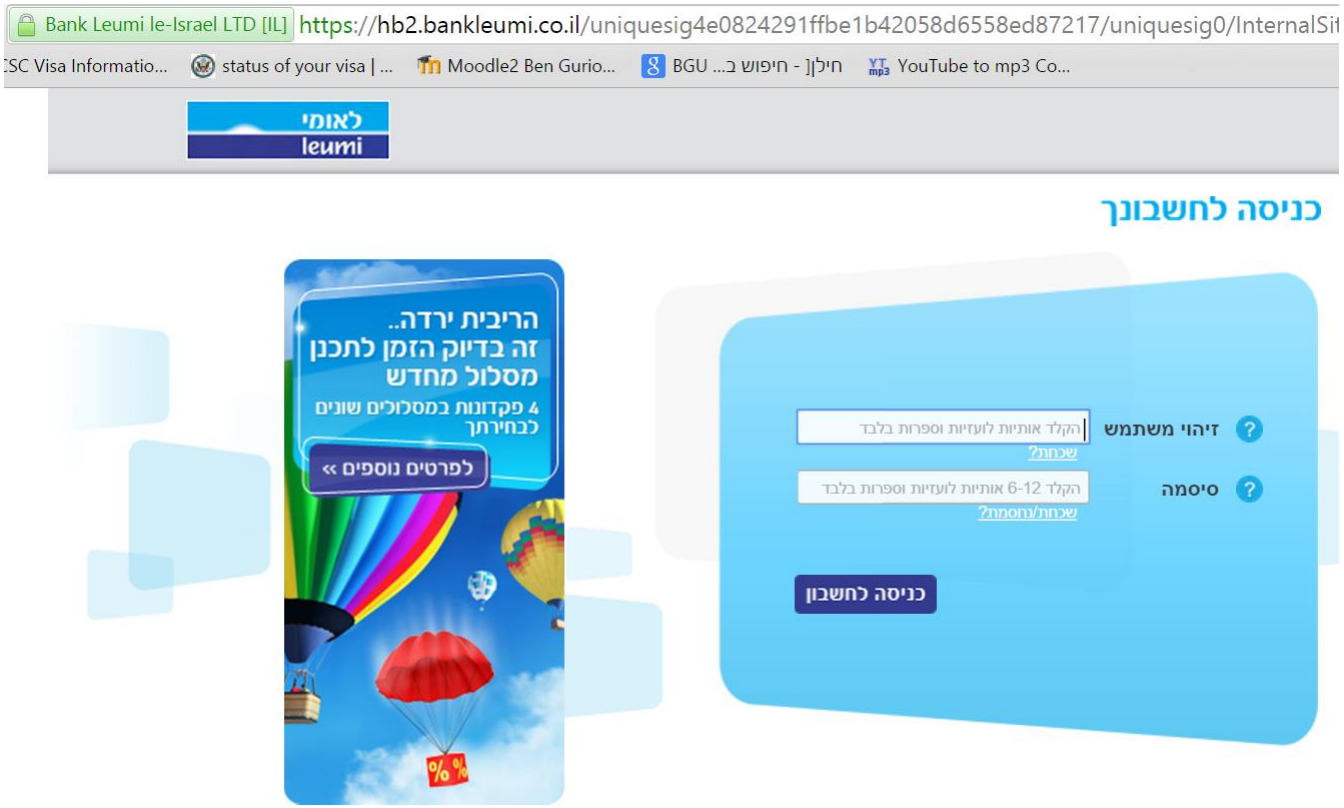
SSL Record Protocol Operation



HTTPS (HTTP over SSL/TLS)

- Combination of HTTP and SSL/TLS to implement secure communication between a Web browser and a Web server
- built into all modern Web browsers
  - URL addresses begin with https://
  - documented in RFC 2818, HTTP Over TLS

HTTPS (HTTP over SSL)



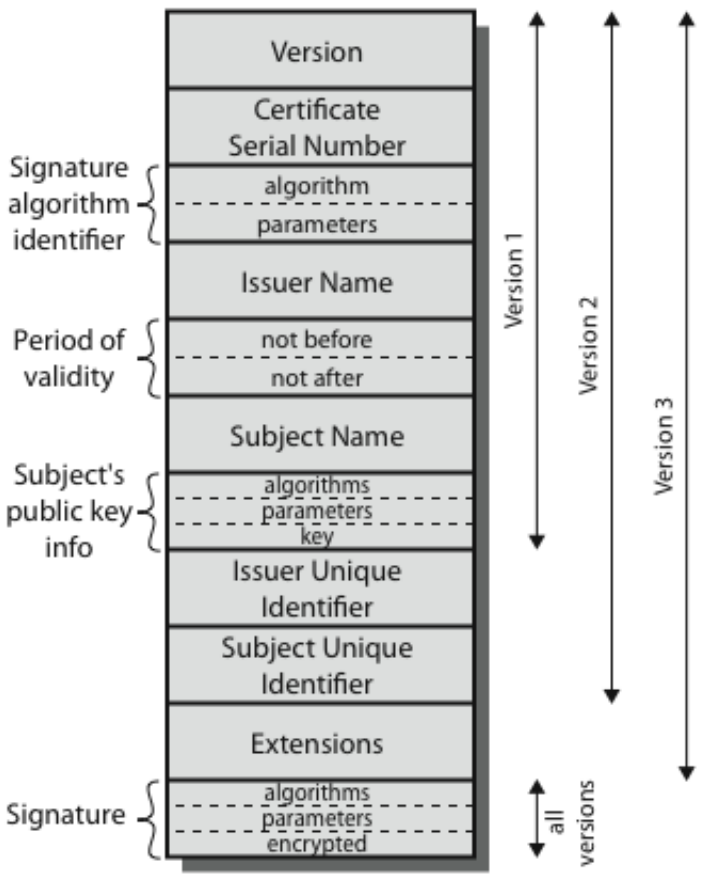
Certificate Authorities

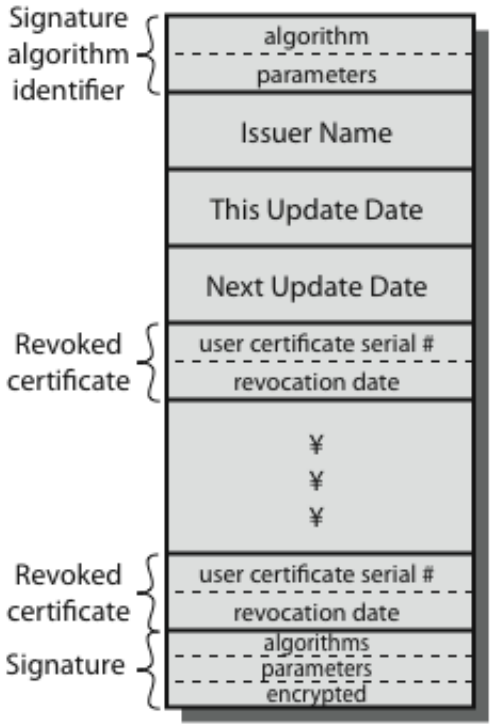
- certificate consists of:
  - a public key plus a User ID of the key owner
  - signed by a third party trusted by community
  - often govt./bank **certificate authority** (CA)
- users obtain certificates from CA
  - create keys & unsigned cert, gives to CA, CA signs cert & attaches sig, returns to user
- other users can verify cert
  - checking sig on cert using CA's public key

X.509 Authentication Service

- universally accepted standard for formatting public-key certificates
  - widely used in network security applications, including IPSec, SSL, SET, and S/MIME
- part of CCITT X.500 directory service standards
- uses public-key crypto & digital signatures
  - algorithms not standardised, but RSA recommended

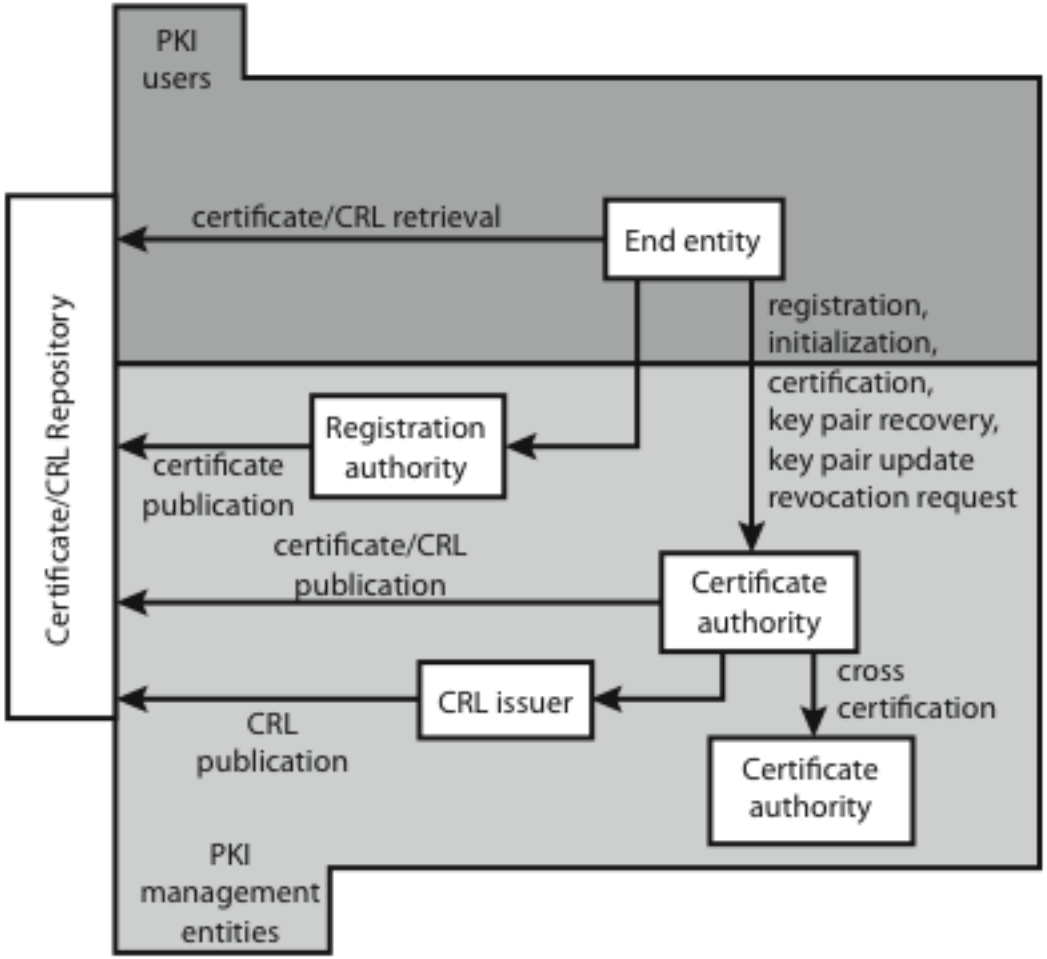
X.509 Certificates





(b) Certificate Revocation List

Public Key Infrastructure



PKIX Management

- functions:
  - registration
  - initialization
  - certification
  - key pair recovery
  - key pair update
  - revocation request
  - cross certification
- protocols: CMP, CMC

SSL/TLS

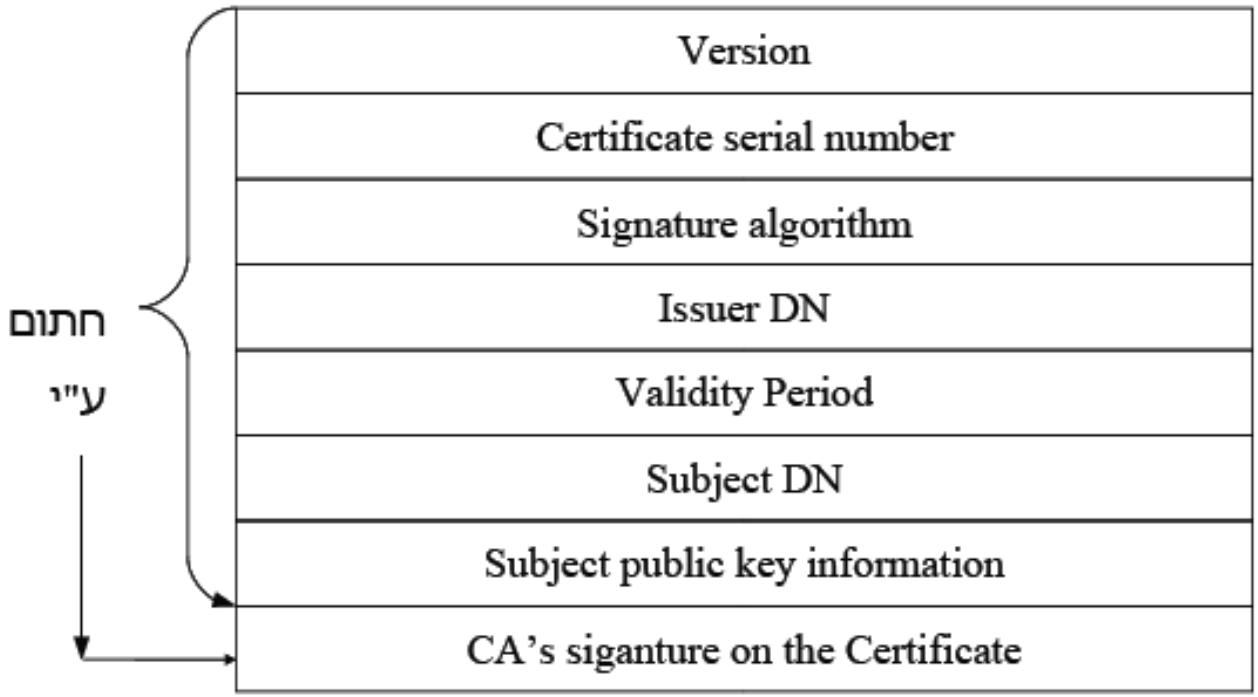
- הפרוטוקול נותן אבטחה לשכבות האפליקציה ו-SSL.
- יתרונות לאבטחה ברמת התובלה:
  - כותב האפליקציה 'פטור' מהתעסקות עם אבטחה.
  - האבטחה מתאימה לכל סוגי האפליקציות.
  - מכיוון שהפרוטוקול עובד מעל TCP, הוא מקבל אוטומטית את המהימנות הקיימת ב-TCP (Ack לכל חבילה, סידור חבילות).
  - מאפשר עבודה עם Packet Filtering Firewalls, זאת מפני שה- headers של TCP/IP אינם מוצפנים.
- חסרונות לאבטחה ברמת התובלה:
  - המידע הנמצא ב- headers של TCP/IP נשלח חשוף ברשת.
  - מכיוון שלא מבוצע אימות על ה- headers של TCP/IP הפרוטוקול לא מספק הגנה בפני ההתקפות:
    - Syn Attack – התקפה על שכבת ה- TCP.
    - IP Spoofing – התקפה על שכבת ה- IP.

אבטחה ברמת האפליקציה

- האבטחה ברמה זו נשענת בעיקר על הצפנה וחתימות דיגיטליות, תוך שימוש באבני הבניין שלמדנו עד כה
- שימוש במפתחות הצפנה דורש תשתית לחלוקת מפתחות בצורה בטוחה
- בדר"כ תוך שימוש בסרטיפיקטים הניתנים ע"י CA עליו סומכים כלל המשתמשים
- סטנדרט מקובל- X.509

אבטחה ברמת האפליקציה

X.509v3 Certificate Format



תזכורת: מודל האמון של PGP (web/ring of trust)

מכיוון ש-PGP היא פחות ברוח ממסדית ויותר חופשית, הנחות האמון שלה הן שונות:

- PGP אינו מניח קיום של רשות שכל המשתמשים סומכים עליה (CA).
- כל משתמש משמש כ-CA ויכול לחתום על סרטיפיקטים של משתמשים אחרים כרצונו.
- כל משתמש מחליט לבד בצורה מפורשת על מי הוא סומך ועל מי לא.

PGP

- המפתחות הפומביים נשלחים בין המשתמשים בעזרת סרטיפיקטים.
- סרטיפיקט מכיל כתובת דואר אלקטרוני ומפתח פומבי.
- הסרטיפיקטים חתומים ע"י משתמשים שונים. למשל: אליס יכולה לבקש מהחברים שלה לחתום על הסרטיפיקט שלה.

- הרעיון: בוב יאסוף חתימות שונות על הסרטיפיקט של אליס. על סמך החתימות הוא יחליט אם הוא מאמין לסרטיפיקט או לא.

PGP

- כיצד מחליט Bob אם להאמין לסרטיפיקט של Alice או לא?
- אינטואיטיבית, Bob צריך להאמין רק לחתימות אשר נעשו ע"י מפתחות אמיתיים של משתמשים שהוא סומך עליהם.
- Bob שומר חתימות ממשתמשים אחרים במחזיק מפתחות (keyring) ובודק האם יש לו מספיק חתימות מהימנות למפתח של Alice.

PGP- דוגמה למחזיק מפתחות

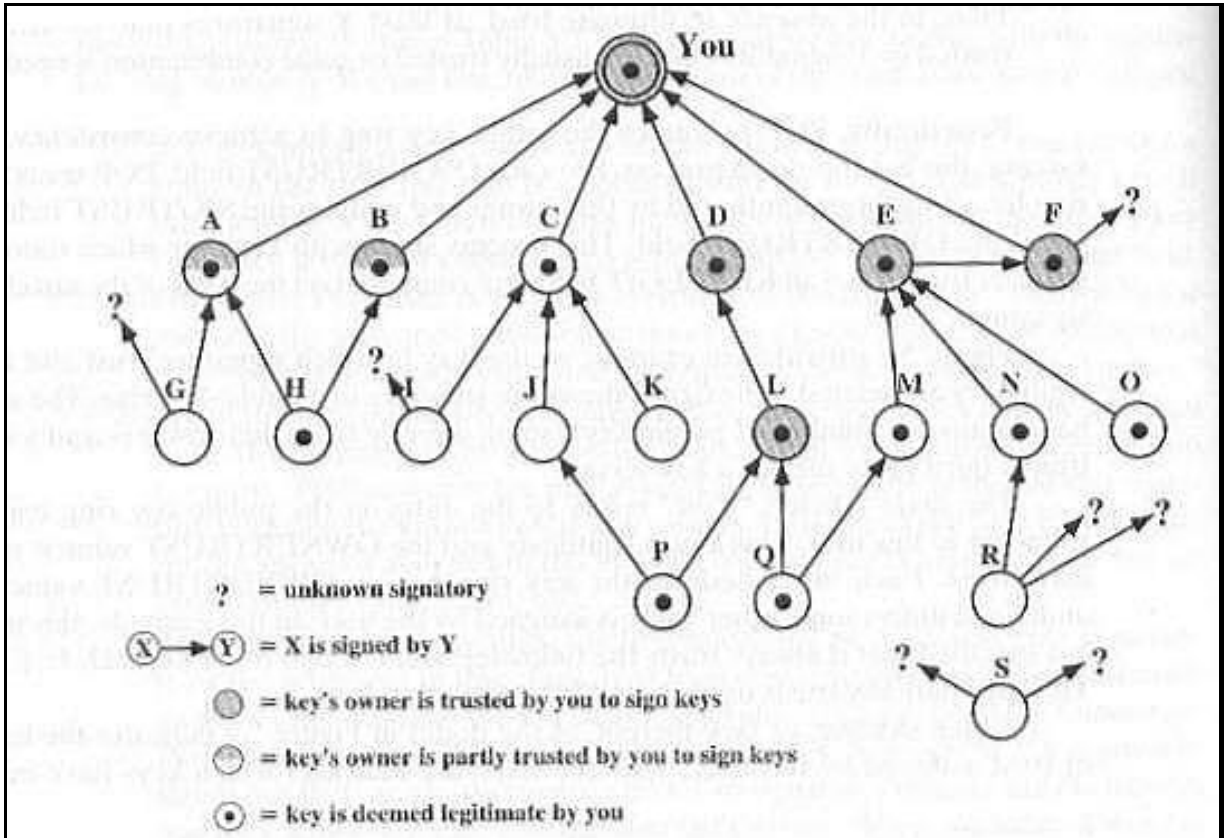


Figure 5.7 PGP Trust Model Example